

BEFORE Placeholder

AFTER

Data Retention & Disposal Policy (Third-Party Security Program Artifacts)

Document classification: Internal

Policy owner: Third-Party Security Program Owner

Privacy owner: Data Protection Officer / Privacy Officer

Version: 0.1

Effective date: _____

Review cadence: Annually or upon material regulatory/business change

1. Purpose

This policy defines retention and disposal requirements for records produced by the Third-Party Security Program to ensure:

- auditability and regulatory assurance,
- effective risk management over time,
- lawful and proportionate retention of personal data (where present).

2. Scope

This policy applies to all Third-Party Security Program artifacts, including:

- intake forms and tiering decisions,
- evidence pack responses and supporting documents,
- gap logs and remediation plans,
- exception requests, approvals, and closure evidence,
- onboarding/offboarding checklists and control validation evidence,

- monitoring outputs relevant to supplier assurance,
- dashboards and management reporting packs.

This policy does not replace corporate-wide records management requirements. Where corporate retention standards are stricter, the stricter standard applies.

3. Principles

Records MUST be:

- **Minimised:** retain only what is needed for assurance and decision evidence.
- **Controlled:** access limited to roles with a business need.
- **Traceable:** records must be attributable to supplier, service, tier, and decision.
- **Time-bound:** retained for defined periods, then disposed securely.
- **Privacy-aware:** personal data retained only where necessary and protected appropriately.

4. Storage and access control

- Program records MUST be stored in an approved internal repository/location with access controls.
- Access MUST be limited to: Third-Party Security Program team, Security Engineering/Architecture, Procurement, Legal Counsel, DPO/Privacy Officer, Technology Risk (as applicable), and auditors/assurance with approved access.
- Sensitive supplier materials (e.g., SOC reports, pen test summaries) MUST be stored in restricted locations and must not be redistributed outside approved recipients.

5. Retention schedule (program artifacts)

Retention periods below are defaults and MUST be adjusted if required by legal hold, active investigation, audit requirements, or contractual obligations.

5.1 Supplier intake and tiering records

- Records: intake forms, tiering decisions, rationale
- Retention: **Contract term + 6 years**
- Rationale: supports audit trail and post-termination inquiries

5.2 Due diligence evidence and assessment outputs

- Records: evidence pack responses, assessment notes, gap logs, remediation plans
- Retention:
 - **Critical suppliers:** Contract term + 6 years
 - **Important suppliers:** Contract term + 4 years
 - **Low suppliers:** Contract term + 2 years
- Rationale: proportionality by tier while maintaining auditability

5.3 Exceptions and residual risk acceptance records

- Records: exception requests, approvals, compensating controls, expiry/renewal, closure evidence
- Retention: **Contract term + 6 years** (all tiers)
- Rationale: formal risk acceptance must remain auditable

5.4 Onboarding and offboarding records

- Records: onboarding readiness checklists, control validation evidence, offboarding checklists, deletion/return confirmations
- Retention:
 - **Critical/Important:** Contract term + 6 years
 - **Low:** Contract term + 2 years
- Rationale: supports proof of secure onboarding and disposal

5.5 Monitoring and periodic review outputs

- Records: review notes, trigger-event reassessments, assurance updates
- Retention:

- **Critical:** 6 years
 - **Important:** 4 years
 - **Low:** 2 years (or retain only latest review)
- Rationale: trend and assurance traceability

5.6 Dashboards and management reporting

- Records: monthly dashboards, quarterly packs, decision logs
- Retention: **3 years**
- Rationale: supports trend analysis and management oversight

5.7 Supplier security attestations / third-party reports

- Records: SOC reports, ISO certificates, pen test summaries (as provided)
- Retention: **Latest version + 2 prior versions** (or contract term + 2 years, whichever is longer)
- Rationale: keep a rolling history without over-retaining

6. Handling personal data within program records

- Program records **SHOULD** avoid storing personal data about supplier employees unless necessary (e.g., named security contact).
- Where personal data is required, it **MUST** be:
 - limited to what is necessary,
 - protected with appropriate access controls,
 - removed/redacted where feasible in archived artifacts.
- DPO/Privacy Officer **MUST** be consulted where records contain sensitive personal data or where deletion requests/rights may apply.

7. Secure disposal and deletion

When retention periods expire (and no legal hold applies), records **MUST** be disposed securely by:

- deleting from primary storage and archives in accordance with approved deletion processes, and/or
- securely shredding physical records (if any),
- ensuring any extracted copies (downloads/email attachments) are also deleted where practicable.

Disposal actions **MUST** be logged (supplier, record category, disposal date, operator).

8. Legal hold and investigations

Where a legal hold, audit, or investigation is active, disposal **MUST** be suspended for relevant records until the hold is lifted. The Third-Party Security Program Owner and Legal Counsel are accountable for confirming hold status.

9. Ownership and compliance

- Third-Party Security Program Owner: accountable for maintaining this policy and ensuring retention processes are implemented.
- DPO/Privacy Officer: accountable for privacy compliance and advice on personal data retention.
- Procurement/Legal/Security: responsible for storing records in approved locations and following retention rules.

10. Exceptions to this policy

Any deviation from this retention schedule **MUST** be approved by:

- Third-Party Security Program Owner, and
- DPO/Privacy Officer where personal data is affected, and
- Legal Counsel where legal/regulatory considerations apply.